

Security Law: CFAA, GDPR, HIPAA & More

Why You Need the Law

Security people make decisions that are *legal decisions*:

"Can I test that system?" (CFAA – written permission needed)

"Can I keep this breach data?" (privacy – harm minimization)

"Do I HAVE to disclose?" (breach notification laws)

Ignorance here is an ethics breach and a career ender. None of this is legal advice – you learn enough to KNOW when to involve counsel.

CFAA (USA, 18 U.S.C. § 1030)

Unauthorized access to protected computers = crime, **even if you didn't 'damage' anything**. The 'authorized/unauthorized' line runs through pen testers and rogue users alike.

Homework: read what "exceeds authorization" means; never rely on 'I had access to it in the lab'.

The 2010s debate over whether it covers 'no damage + just viewing' data – you'll hear 'CFAA with great power...'. The safe reading: don't access what you're not authorized to.

GDPR (EU) – the data-privacy star

Personal data → rights: access, erasure, portability, consent control

Data breach notification: ~72 hours to notify authority (EU, plus national rules)

DPO / ROPA (policies, records)

Huge fines: up to 4% global turnover / €20M

Extra-territorial scope: applies to ANY company processing EU residents' data

Ask in any role: "where is the personal data flowing, and what privacy obligations attach?" That question is half of a SOC analyst's day in 2026.

HIPAA (US healthcare)

PHI (Protected Health Information) safeguards: administrative, physical, technical

Breach notification: covered entities to HHS, patients, media (if 500+)

Encryption isn't mandated – *safeguards* are – but encryption is how you mostly comply

CCPA/CPRA (California) & the US state patchwork

Consumer rights: deletion, 'do not sell', access

The US has no single federal GDPR; states do their own thing – privacy programs are increasingly 'state law aware'

PCI DSS (payment card data)

Not law but CONTRACT (mandatory via card networks)

12 requirements: firewall, strong passwords, encrypted cardholder data, restrict physical/logical access, logging, testing, vendor management...

The Breach Notification Matrix (the instant panic-solver)

Law	What triggers	How fast	To whom
GDPR	risk to rights/freedoms	72h	authority (+ often users)
HIPAA	unsecured PHI	60 days	HHS/patients
State laws	personal data	varies (often 30d)	state AGs

Law	What triggers	How fast	To whom
PCI	cardholder data	as contract says	acquiring bank

In practice: the legal team carries the notification call; *you* carry the facts (what data, how many, when, exposure). Your timestamped, hashed evidence (M14) is what makes notification accurate.

[← Security Policies, Standards...](#)

[Ethics: The Human Rules of Sec...](#)